

## **Risk Register for a Fictional Small-Scale Company**

### **Assumptions:**

**Company Name:** Life Retail Ltd.

**Industry:** Online E-commerce Company

**Employees:** 40

**Location:** Canada

### **Business Description**

Life Retail Ltd. is an e-commerce marketplace that sells varieties of goods through its website. The company stores customer information, payment records (processed through a third-party payment provider), employee records, supplier contracts, and inventory data in cloud-based systems. Employees work both remotely and from a small office.

### **Critical Assets**

- Customer Database
- Customer accounts
- Inventory database
- Company laptops
- Vendor and supply chain data
- Cloud storage
- E-commerce Website
- Employee records
- Financial records
- Business reputation

### **RISK SCORING METHOD (5x5 risk matrix)**

| <b>Likelihood</b> | <b>Score</b> | <b>Impact</b> | <b>Score</b> |
|-------------------|--------------|---------------|--------------|
| Rare              | 1            | Insignificant | 1            |
| Unlikely          | 2            | Minor         | 2            |
| Possible          | 3            | moderate      | 3            |
| Likely            | 4            | Major         | 4            |
| Certain           | 5            | Severe        | 5            |

| Score | Risk Level    |
|-------|---------------|
| 1-5   | Low           |
| 6-10  | Medium        |
| 11-15 | High          |
| 16-20 | Critical      |
| 21-25 | Very Critical |

| Risk ID | Risk Description                                                                               | Asset Affected               | Likelihood | Impact | Risk Score | Risk Level    | NIST Function | Mitigation                                                                                                                                      |
|---------|------------------------------------------------------------------------------------------------|------------------------------|------------|--------|------------|---------------|---------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| 1       | Lost or Stolen employee laptops                                                                | Company Laptops              | 3          | 4      | 12         | High          | Protect       | Full disk encryption and remote device wipe                                                                                                     |
| 2       | Corrupt inventory database due to ransomware                                                   | Inventory Database           | 3          | 5      | 15         | High          | Recover       | Implement automated backup validation test                                                                                                      |
| 3       | Lack of mandatory clauses and notification timelines due to inadequate vendor security posture | Vendor and supply chain data | 2          | 3      | 6          | Medium        | Govern        | Update vendor contract templates with mandatory cybersecurity requirements.                                                                     |
| 4       | Customers using the same password across multiple platform                                     | Customer Account             | 4          | 4      | 16         | Critical      | Identify      | Use Multi Factor Authentication for all accounts                                                                                                |
| 5       | Publicly exposed storage container due to misconfiguration                                     | Cloud Storage                | 5          | 5      | 25         | Very Critical | Protect       | Use data classification to prevent personally identifiable information. Implement infrastructure-as-a-code(terraform) scanning to detect public |

|    |                                                                                            |                     |   |   |    |        |         |                                                                                                                                                             |
|----|--------------------------------------------------------------------------------------------|---------------------|---|---|----|--------|---------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                                                                            |                     |   |   |    |        |         | ACLs pre-deployment                                                                                                                                         |
| 6  | Delayed public disclosure after a breach                                                   | Business Reputation | 3 | 4 | 12 | High   | Recover | Include PR team in the incident response team and establish a 72 hour and 48 hours for regulators and customer notification respectively (GDPR requirement) |
| 7  | Unavailable website due to Distributed Denial of Service                                   | E-commerce Website  | 3 | 5 | 15 | High   | Respond | Develop an incidence response playbook and DDOS protection service.                                                                                         |
| 8  | Abnormal volume of database queries allowing accounts to slowly exfiltrate records         | Customer Database   | 3 | 4 | 12 | High   | Detect  | Implement database activity monitoring with alerts                                                                                                          |
| 9  | Employee record system encrypted due to ransomware                                         | Employee Records    | 2 | 4 | 8  | Medium | Recover | Create a manual payroll run procedure as a failover                                                                                                         |
| 10 | A compromised account initiates a wire transfer due to lack of secondary means of approval | Financial Records   | 3 | 4 | 12 | High   | Respond | Enable dual authorization for wire transfers.                                                                                                               |

### Mapping to the NIST CSF 2.0 Functions

| Function | Risk  |
|----------|-------|
| Govern   | 3     |
| Identify | 4     |
| Protect  | 1,5   |
| Detect   | 8     |
| Respond  | 7,10  |
| Recover  | 2,6,9 |